

LOG ANALYSIS & ALERTING TOOL

FOR A RETAIL CHAIN

Detection Rules, Log-Review Dashboard & Incident-Response Documentation

Prepared by: Sara Irshad

Role: Member 4 — Individual Contributor

Tool: OSSEC (Host-Based Intrusion Detection System)

SDC Internship — Defensive Security Track

September 2026

1. Objective

This document covers the individual deliverable for Member 4 of the "Log Analysis & Alerting Tool for a Retail Chain" project. The objective is to design, implement, and validate host-based intrusion detection using OSSEC, producing a working set of detection rules, a sample log-review report, and documented incident-response procedures for each alert type — modeled on how a defensive security analyst would monitor a retail organization's point-of-sale (POS) infrastructure.

2. Tool & Environment

OSSEC is an open-source Host-based Intrusion Detection System (HIDS) that performs log analysis, file integrity monitoring, rootkit detection, and real-time alerting. It was chosen for this piece of the project because it directly supports the required capabilities: custom detection rules, log-based alerting, and file integrity checks — all of which map onto realistic retail security concerns such as POS terminal access and configuration tampering.

Lab environment:

- Host: Windows machine, 16 GB RAM
- Hypervisor: Oracle VirtualBox
- Guest OS: Ubuntu Server 26.04.1 LTS (2 GB RAM, 20 GB disk)
- HIDS: OSSEC-HIDS v3.7.0, installed from source in "local" mode
- Monitoring scope: SSH authentication logs, sudo/privileged commands, user-account changes, and a simulated POS configuration file at `/etc/pos/pos_config.conf`

3. Custom Detection Rules

Five custom rules were authored in `/var/ossec/rules/local_rules.xml`, extending OSSEC's base ruleset and framed around retail POS terminology to reflect a realistic client engagement:

Rule ID	Alert Name	Trigger Condition	Severity
100010	Failed Login – POS Admin Terminal	Single failed SSH password authentication against the POS admin terminal (chained to OSSEC base rule 5716).	5 – Low
100011	Brute-Force Attempt – POS Admin Terminal	6 or more failed logins (rule 100010) from the same source within a 120-second window — correlation rule.	10 – High
100012	Unauthorized Account Creation	A new local user account is created on the retail server outside of change-management process.	8 – High
100013	Privileged Command Execution	A sudo / privileged command is executed on the POS server, flagged for admin-activity review.	6 – Medium
100014	POS Configuration File Tampering	File Integrity Monitoring (syscheck) detects an unexpected modification to the POS configuration file.	7 – Medium-High

Rule 100010 and 100011 work together: 100010 flags each individual failed login, while 100011 is a frequency/correlation rule that escalates to a high-severity brute-force alert once six matches of 100010 occur from the same source within a two-minute window — demonstrating both atomic and correlated detection logic.

4. Testing & Evidence

Each rule was validated against the live OSSEC daemon (not just the offline rule tester) to confirm real-world detection, using a combination of manual SSH login attempts, simulated user/sudo events, and direct file modification.

4.1 OSSEC Installed and Running

```
install -m 0750 -o ossecr -g ossec -d /var/ossec/queue/agent-info
install -m 0750 -o ossecr -g ossec -d /var/ossec/queue/agentless
install -m 0750 -o ossecr -g ossec -d /var/ossec/queue/ids
install -m 0640 -o root -g ossec -d /etc/decoder.xml /var/ossec/etc/
rm -f /var/ossec/etc/shared/merged.mg

- System is Debian (Ubuntu or derivative).
- Init script modified to start OSSEC HIDS during boot.
- Configuration finished properly.

- To start OSSEC HIDS:
  /var/ossec/bin/ossec-control start

- To stop OSSEC HIDS:
  /var/ossec/bin/ossec-control stop

- The configuration can be viewed or modified at /var/ossec/etc/ossec.conf

Thanks for using the OSSEC HIDS.
If you have any question, suggestion or if you find any bug,
contact us at https://github.com/ossec/ossec-hids or using
our public maillist at
https://groups.google.com/forum/#!forum/ossec-list

More information can be found at http://www.ossec.net
--- Press ENTER to finish (maybe more information below). ---

sara@ossec-lab:~/ossec-hids-3.7.0$ sudo /var/ossec/bin/ossec-control start
Starting OSSEC HIDS v3.7.0...
2026/09/02 09:41:45 ossec-malld: INFO: E-Mail notification disabled. Clean Exit.
Started ossec-malld...
Started ossec-execd...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
sara@ossec-lab:~/ossec-hids-3.7.0$ sudo /var/ossec/bin/ossec-control status
ossec-monitord is running...
ossec-logcollector is running...
ossec-syscheckd is running...
ossec-analysisd is running...
ossec-malld not running...
ossec-execd is running...
sara@ossec-lab:~/ossec-hids-3.7.0$
```

Figure 1 — OSSEC HIDS installed successfully; all core daemons (monitord, logcollector, syscheckd, analysisd, execd) confirmed running.

4.2 Custom Rules Loaded Without Errors

```
sara@ossec-lab:~/ossec-hids-3.7.0$ sudo /var/ossec/bin/ossec-logtest
2026/09/02 09:37:56 ossec-testrule: INFO: Reading local decoder file.
2026/09/02 09:37:56 ossec-testrule: INFO: Started (pid: 4300).
ossec-testrule: Type one log per line.

^C
sara@ossec-lab:~/ossec-hids-3.7.0$ sudo /var/ossec/bin/ossec-control restart
ossec-monitord not running ..
ossec-logcollector not running ..
ossec-syscheckd not running ..
ossec-analysisd not running ..
ossec-malld not running ..
ossec-execd not running ..
OSSEC HIDS v3.7.0 Stopped
Starting OSSEC HIDS v3.7.0...
2026/09/02 09:39:02 ossec-malld: INFO: E-Mail notification disabled. Clean Exit.
Started ossec-malld...
Started ossec-execd...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
sara@ossec-lab:~/ossec-hids-3.7.0$
```

Figure 2 — OSSEC restarted cleanly after local_rules.xml was updated, confirming valid XML and successful rule load.

4.3 Rule 100010 — Failed Login Detection (Live)

```

sara@ossec-lab:~$ sudo /var/ossec/bin/ossec-logtest
2026/09/03 14:36:05 ossec-testrule: INFO: Reading local decoder file.
2026/09/03 14:36:05 ossec-testrule: INFO: Started (pid: 3667).
ossec-testrule: Type one log per line.

"C
sara@ossec-lab:~$ sudo /var/ossec/bin/ossec-control restart
Killing ossec-monitord...
Killing ossec-logcollector...
Killing ossec-syscheckd...
Killing ossec-analysisd...
ossec-maild not running...
Killing ossec-execd...
OSSEC HIDS v3.7.0 Stopped
Starting OSSEC HIDS v3.7.0...
2026/09/03 14:37:14 ossec-maild: INFO: E-Mail notification disabled. Clean Exit.
Started ossec-maild...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
sara@ossec-lab:~$ for i in {1..6}; do sshpass -p wrongpass123 ssh -o StrictHostKeyChecking=no sara@localhost; done
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
sara@ossec-lab:~$ sudo grep -E "100010|100011" /var/ossec/logs/alerts/alerts.log | tail -30
2026-09-03T14:23:02.521895+00:00 ossec-lab sudo: sara : TTY/dev/tty1 : PKD=/home/sara : USER=root : COMMAND=/usr/bin/grep -E 100010|100011 /var/ossec/logs/alerts/alerts.log
Rule: 100010 (level 5) -> 'Failed login attempt detected on POS admin terminal (SSH).'

```

Figure 3 — Six consecutive failed SSH logins against the live OSSEC daemon, each correctly matched to custom Rule 100010.

4.4 Rule 100011 — Brute-Force Correlation (Live)

```

sara@ossec-lab:~$ for i in {1..8}; do sshpass -p wrongpass123 ssh -o StrictHostKeyChecking=no sara@localhost; sleep 3; done
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
Permission denied, please try again.
sara@ossec-lab:~$ sudo grep -E "100010|100011" /var/ossec/logs/alerts/alerts.log | tail -20
2026-09-03T14:03:54.050444+00:00 ossec-lab sudo: sara : TTY/dev/tty1 : PKD=/home/sara : USER=root : COMMAND=/usr/bin/grep -E 100010|100011 /var/ossec/logs/alerts/alerts.log
Rule: 100010 (level 5) -> 'Failed login attempt detected on POS admin terminal (SSH).'

```

Figure 4 — After repeated failures within the 120-second window, OSSEC escalates and fires the correlated Rule 100011 (level 10) brute-force alert.

4.5 Rule 100014 — File Integrity Violation

```

sara@ossec-lab:~$ sudo grep "100014" /var/ossec/logs/alerts/alerts.log
(sudo: authenticate) Password:
Rule: 100014 (level 7) -> 'Unexpected modification to POS configuration file detected by file integrity monitoring.'

```

Figure 5 — syscheck detects and alerts on an unauthorized modification to the monitored POS configuration file.

5. Sample Log-Review Report / Alert Dashboard

The table below summarizes representative alerts generated during testing, in the format an analyst would use for a daily log-review pass:

Time	Rule (Level)	Raw Log Excerpt	Interpretation
09:47:41	100010 (5)	sshd-session: Failed password for sara from 127.0.0.1 port 50704 ssh2	Failed login on POS admin terminal
14:45:34	100011 (10)	6x consecutive failed SSH authentications within 120s from 127.0.0.1	Brute-force pattern confirmed
10:00:00	100012 (8)	useradd: new user: name=hacker, UID=1001, home=/home/hacker	Unauthorized account creation
10:05:00	100013 (6)	sudo: sara : PWD=/home/sara ; USER=root ; COMMAND=/bin/bash	Privileged command executed
—	100014 (7)	syscheck: modified file /etc/pos/pos_config.conf	POS config file tampering detected

6. Incident-Response Procedures

The following response steps define what an analyst should do the moment each alert type fires for real:

Rule 100010 — Failed Login on POS Admin Terminal

- Verify the source IP against the known-admin IP list; unrecognized source IPs are treated as suspicious.
- Check whether the failed attempt is isolated or part of a repeating pattern (watch for escalation to Rule 100011).
- If isolated and from a known admin, no action needed beyond logging.
- If from an unknown source, monitor closely for the next 10 minutes for repeat attempts.

Rule 100011 — Brute-Force Attack on POS Admin Terminal

- Treat as active incident — do not wait for further confirmation.
- Immediately block the source IP at the firewall / use OSSEC active-response to auto-drop the connection.
- Lock or reset the targeted account's credentials as a precaution.
- Review authentication logs for the preceding 24 hours to confirm no successful login occurred from the same source.
- Escalate to the security lead and document the incident timeline.

Rule 100012 — Unauthorized Account Creation

- Immediately identify who created the account and cross-check against approved change requests.
- If unauthorized, disable the new account and reset the root/administrator password.
- Review recent sudo/privileged activity on the host to identify how access was obtained.
- Preserve relevant logs before remediation for later root-cause analysis.

Rule 100013 — Privileged Command Execution

- Review the exact command executed and the business justification for it.
- Cross-reference against the on-call schedule / approved maintenance window.
- If unauthorized, treat as potential privilege misuse — escalate immediately.
- If authorized, document as expected admin activity and close the alert.

Rule 100014 — POS Configuration File Tampering

- Compare the current file contents against the last known-good backup/version control copy.
- Restore the configuration file from a verified backup if unauthorized changes are confirmed.
- Investigate which user/process made the modification via syscheck and auth logs.
- If payment-processing settings were altered, treat as a high-priority incident and notify the retail operations team immediately.

7. Conclusion

This piece demonstrates a working, testable OSSEC deployment covering five distinct detection scenarios relevant to retail POS security — authentication abuse, privilege escalation, account-management changes, and configuration-file tampering — each validated against the live detection engine with documented response procedures. Combined with the other group members' components, this contributes host-based log analysis and alerting coverage to the overall "Log Analysis & Alerting Tool for a Retail Chain" deliverable.